École Supérieure des Communications de Tunis

SUP'COM

Tessera

Plateforme intelligente de billetterie numérique

Anti-contrefaçon, anti-truquage et anti-scalping

CAHIER DES CHARGES

Spécifications fonctionnelles, techniques et organisationnelles

---

Réalisé par :

Mohamed Fourat Boujdaria
Brahim Cheikh

Enseignant : Dr. Ing. Mohamed-Becha Kaâniche

Classe : INDP3 CySeD

Année Universitaire : 2026–2027

Résumé exécutif

Tessera est une plateforme PWA/SPA de billetterie destinée aux grands événements sportifs et culturels. Elle couvre l'achat, l'émission, la présentation, le transfert autorisé et le contrôle d'accès des billets numériques. Son objectif est de réduire les risques de contrefaçon, de modification frauduleuse, de duplication, de rejeu et de revente spéculative.

La singularité du projet est la combinaison de trois mécanismes appliqués au visuel du billet : (i) un filigrane robuste associé à l'organisateur, (ii) une empreinte robuste individualisée associée à chaque exemplaire téléchargé, et (iii) un sceau stéganographique fragile contenant des données d'accès chiffrées et authentifiées. Ces mécanismes permettent de prouver la provenance d'une image, de détecter sa modification et d'attribuer une fuite ; ils ne remplacent pas la validation cryptographique en ligne.

Le serveur applicatif repose sur Java 25, Jakarta EE 11 et WildFly 42. L'application adopte une démarche Shift-Left : les menaces, exigences, tests et critères d'acceptation sont définis avant l'implémentation. Le périmètre est dimensionné pour un binôme : un noyau fonctionnel (priorité Must) est livré en priorité et les autres fonctions sont ordonnées par un plan de repli explicite (section 3).

Périmètre de garantie

Un billet est accepté uniquement si le serveur confirme son authenticité, son affectation, sa validité temporelle et son état d'utilisation. Le visuel, le QR code et les données cachées sont des supports de preuve et de transport, non des autorités autonomes. Une capture d'écran ou une image reproduite ne doit jamais suffire à obtenir l'accès.

Sommaire

Résumé exécutif **1**

1 Cadre du projet et diagnostic métier **3**
1.1 Identité, équipe et dépôt . . . 3
1.2 Limites des billets numériques classiques et réponses de Tessera . . . 3
1.3 Rôle et complémentarité des trois techniques . . . 4
1.3.1 Watermarking — preuve de provenance . . . 5
1.3.2 Stéganographie — sceau d'intégrité du fichier . . . 5
1.3.3 Fingerprinting — attribution d'un exemplaire . . . 6
1.3.4 Analyse d'une image suspecte . . . 6
1.4 Scénario de fraude synthétique . . . 7

2 Cahier des charges fonctionnel et technique **7**
2.1 Pitch et objectifs . . . 7
2.1.1 Objectifs mesurables . . . 7
2.2 Parcours nominal de bout en bout . . . 7
2.2.1 Cycle de vie du billet . . . 8
2.3 Exigences fonctionnelles . . . 8
2.4 Rôles et habilitations RBAC/ABAC . . . 9
2.5 Architecture technique cible . . . 10
2.5.1 Vue logique . . . 10
2.5.2 Frontières de confiance . . . 11
2.5.3 Flux REST indicatifs . . . 12
2.5.4 Socle Java 25 / Jakarta EE 11 / WildFly 42 . . . 12
2.6 Exigences non fonctionnelles . . . 13
2.7 Exigences réglementaires et vie privée . . . 13
2.7.1 RGPD et minimisation . . . 13
2.7.2 Revente et scalping : règle de prudence juridique . . . 14

3 Plan de réalisation et livrables **14**
3.1 Dimensionnement pour un binôme . . . 14
3.2 Découpage et planning . . . 15
3.3 Répartition et méthode de travail . . . 16
3.4 Correspondance avec le programme du cours . . . 16
3.5 Risques et plan de repli . . . 16
3.6 Definition of Done . . . 17

1 Cadre du projet et diagnostic métier

1.1 Identité, équipe et dépôt

Le nom TESSERA fait référence à la tessera romaine, jeton physique servant notamment de titre d'accès. Le projet transpose cette idée en un titre numérique vérifiable, attribuable et révocable.

Élément	Définition
Nom	Tessera
Domaine	Billetterie numérique d'événements sportifs et culturels
Utilisateurs principaux	Organisateurs, acheteurs, agents de contrôle, auditeurs anti-fraude, administrateurs
Canal	Progressive Web Application / Single Page Application
Back-end	Jakarta EE 11 sur WildFly 42, Java 25
Finalité de sécurité	Authenticité, intégrité, confidentialité, disponibilité et traçabilité des titres d'accès
Équipe	Équipe 8 (binôme) : Mohamed Fourat Boujdaria, Brahim Cheikh
Cadre	Atelier Sécurité applicative, SUP'COM, INDP3 CySeD. Enseignant : Dr. Ing. Mohamed-Becha Kaâniche
Dépôt GitHub	`https://github.com/brahim403/secure-information-hiding`

Le dépôt est organisé en `/docs` (documents PDF), `/backend`, `/frontend`, `/hiding-engine` (moteur de marquage), `/infra` (déploiement) et `/tests`.

1.2 Limites des billets numériques classiques et réponses de Tessera

Les billets numériques courants (QR code statique, PDF, capture d'écran) présentent les faiblesses suivantes ; le tableau indique la réponse apportée par l'architecture TESSERA.

Dimension	Faiblesse d'un billet classique	Réponse de Tessera
Authenticité	Le visuel ou un identifiant isolé peut être copié.	Signature Ed25519 vérifiée côté serveur, identifiant opaque et vérification de l'émetteur.
Intégrité	Une modification du siège, de la porte ou de la date peut ne pas être détectée par un simple contrôle visuel.	Données canoniques signées, empreinte cryptographique et sceau chiffré/authentifié.
Attribution	Un billet partagé ne permet pas toujours d'identifier l'exemplaire divulgué.	Empreinte individualisée et pseudonyme de détenteur, avec accès restreint à la table de correspondance.

Dimension	Faiblesse d'un billet classique	Réponse de Tessera
Anti-rejeu	Une capture d'écran peut être présentée plusieurs fois.	État transactionnel central, validation en ligne, consommation atomique et identifiant de scan à usage unique.
Scalping	Achat automatisé et revente hors circuit officiel difficiles à relier.	Limitation de débit, quotas d'achat, détection d'anomalies, transfert officiel et historique d'affectation.
Contrôle d'accès	Permissions définies uniquement par type d'utilisateur.	RBAC complété par des attributs : événement, porte, créneau, statut et appareil autorisé.
Audit	Journalisation non structurée ou modifiable.	Événements d'audit horodatés, corrélés, protégés contre l'altération et consultables par rôle dédié.
Protection des données	Collecte potentiellement excessive d'informations personnelles.	Minimisation, pseudonymisation, chiffrement, rétention limitée et séparation des données d'identité.

1.3 Rôle et complémentarité des trois techniques

Les trois techniques opèrent sur le visuel du billet (image PNG), mais elles ne jouent pas le même rôle. La décision d'admission appartient toujours au serveur, à partir du jeton opaque présenté par QR code. Les marques servent à prouver la provenance d'une image, à détecter sa modification et à attribuer une fuite. Elles sont lues par un seul composant, le service d'analyse d'image (utilisé par l'auditeur anti-fraude), et non par le terminal de scan.

Mécanisme	Technique retenue	Robustesse	Contenu	Rôle métier
Filigrane d'émetteur	Insertion en domaine fréquentiel (DCT, coefficients de moyenne fréquence, étalement de spectre)	Robuste : redimensionnement, compression modérée, recadrage limité	Identifiant d'organisateur (constant)	Provenance
Empreinte de copie	Même moteur que le filigrane, mode « code individuel » avec code correcteur d'erreurs	Robuste (mêmes transformations)	Identifiant pseudonyme de l'exemplaire (48 bits ou plus)	Attribution d'une fuite
Sceau stéganographique	LSB à positions pseudo-aléatoires dérivées d'une clé serveur	Fragile par conception : détruit par toute recompression ou modification de pixels	Payload chiffré AES-GCM et signé Ed25519	Intégrité du fichier original

1.3.1 Watermarking — preuve de provenance

Un filigrane numérique est intégré au rendu du billet pour représenter l'organisateur ou l'émetteur. Il vise à rendre une copie frauduleuse plus difficile à faire passer pour un billet officiel et à faciliter la reconnaissance de la provenance. Le filigrane doit être conçu pour résister à des transformations courantes (redimensionnement, compression modérée, recadrage limité), puis évalué sur un corpus d'images représentatif.

Limite : un filigrane invisible n'est pas mathématiquement inaltérable. Il peut être supprimé ou dégradé par des transformations suffisamment agressives. Il constitue un signal de provenance, pas une preuve cryptographique autonome.

1.3.2 Stéganographie — sceau d'intégrité du fichier

Le visuel contient un payload structuré comprenant au minimum : identifiant du billet, identifiant d'événement, catégorie/porte, rang/siège, version du format et référence de signature. Le payload est chiffré avec un chiffrement authentifié (par exemple AES-GCM) avant son insertion dans le support visuel. La clé est conservée côté serveur ou dans un service de gestion de clés ; elle n'est jamais embarquée dans l'image.

La signature Ed25519 porte sur une représentation canonique des données métier (ou sur leur empreinte) et permet de détecter toute modification des champs signés. Le chiffrement protège la confidentialité du payload ; la signature garantit l'origine et l'intégrité. Ces deux propriétés ne doivent pas être confondues.

Le sceau est volontairement fragile : toute modification de pixels ou recompression le rend illisible. Sa présence et sa validité attestent que le fichier est l'original émis par Tessera ; son

absence ne prouve pas une fraude, puisqu'une capture d'écran légitime le détruit. Il n'est lu que par le serveur, lors de l'analyse d'une image.

Limite : la stéganographie seule ne protège pas contre la copie bit à bit de l'image. Un attaquant peut copier un billet valide ; la détection de duplication dépend donc de l'état serveur et du contrôle anti-rejeu.

1.3.3 Fingerprinting — attribution d'un exemplaire

Lors du téléchargement, le serveur génère un rendu individualisé contenant une empreinte pseudonyme liée à l'affectation du billet. L'empreinte ne doit pas exposer directement le nom, l'adresse électronique ou un identifiant personnel en clair. Une table séparée permet, sous habilitation et justification, de relier une empreinte à une affectation.

Le fingerprinting vise à attribuer une fuite à un exemplaire distribué. Il ne prouve pas à lui seul que le détenteur a volontairement divulgué le billet : un appareil compromis, un partage non autorisé ou une fuite par un tiers restent possibles. Toute sanction doit donc être précédée d'une investigation et d'une procédure contradictoire.

1.3.4 Analyse d'une image suspecte

Lorsqu'une image circule hors de la plateforme, l'auditeur anti-fraude la soumet au service d'analyse :

1. le filigrane est extrait : il indique si l'image provient d'un organisateur de Tessera ;
2. l'empreinte est extraite et résolue par la table de correspondance, sous justification enregistrée : elle désigne l'exemplaire et l'affectation ;
3. le sceau est lu : valide, il atteste un fichier original non modifié ; absent ou invalide, il indique une copie recompressée ou modifiée, sans empêcher l'attribution par les deux marques robustes.

Si les marques sont absentes ou illisibles, le résultat est « non concluant » : le système ne produit jamais d'attribution douteuse.

Table 2 – Synergie des mécanismes

Technique	**Question traitée**	**Apport et limite principale**
Filigrane	Qui a émis ?	Provenance visuelle et résistance aux copies ordinaires ; robustesse non absolue.
Empreinte	Quel exemplaire a fuité ?	Attribution pseudonyme d'une copie, même recompressée ; ne démontre pas automatiquement la culpabilité du titulaire.
Sceau + cryptographie	Le fichier est-il l'original ?	Détection de toute modification de pixels et transport des métadonnées ; ne bloque pas la copie du fichier.
Validation serveur	Le billet peut-il entrer maintenant ?	Vérifie signature, statut, événement, créneau et absence d'utilisation antérieure.

1.4 Scénario de fraude synthétique

Un scalper achète plusieurs billets avec des comptes automatisés, télécharge des images et les publie sur une place de marché secondaire. Un acheteur tiers reçoit une capture d'écran. À l'entrée, le scan transmet le jeton au serveur. Si le billet a déjà été consommé, transféré ou révoqué, le serveur refuse l'accès. Si le billet est encore valide mais que le visuel a été modifié, la signature ou l'authentification du payload échoue lors de l'analyse. Si une image divulguée est retrouvée, l'auditeur la soumet à l'analyse : le filigrane identifie l'émetteur officiel et l'empreinte pseudonyme permet de remonter à l'exemplaire distribué, sous procédure d'audit.

2 Cahier des charges fonctionnel et technique

2.1 Pitch et objectifs

Tessera fournit une chaîne de confiance depuis la mise en vente jusqu'au contrôle d'accès. L'organisateur publie un événement et ses quotas. L'acheteur sélectionne une place, paie via un prestataire externe et reçoit un billet individualisé. Le contrôleur scanne le code présenté ; le serveur vérifie les preuves et met à jour l'état du billet de manière atomique. En cas de transfert autorisé, l'ancien exemplaire est invalidé et un nouveau rendu est émis.

2.1.1 Objectifs mesurables

- Empêcher qu'un même billet soit accepté deux fois : une seule transition atomique vers l'état `CONSUMED`.
- Rejeter tout billet dont la signature, le statut, l'événement ou le créneau ne sont pas valides.
- Appliquer les quotas d'achat et les règles anti-automatisation au moment de la réservation et du paiement.
- Rendre une image divulguée attribuable à un exemplaire, avec un taux de récupération des marques mesuré, ou conclure explicitement « non concluant », sans afficher d'identifiant personnel dans le visuel.
- Journaliser les opérations sensibles sans stocker de secrets, de données bancaires ou le contenu intégral des jetons.

2.2 Parcours nominal de bout en bout

1. **Publication :** l'organisateur crée l'événement, configure les zones, les portes, les places, les tarifs, les périodes de vente et les règles de transfert.
2. **Réservation :** l'acheteur s'authentifie, sélectionne une place et obtient une réservation temporaire. Le serveur applique les quotas, le contrôle anti-bot et une expiration courte.
3. **Paiement :** le client est redirigé vers un prestataire de paiement. Le back-end valide le résultat à partir d'une notification serveur-à-serveur authentifiée ; le retour navigateur seul ne fait pas foi.
4. **Émission :** le service de billetterie crée un identifiant opaque, associe les données d'accès, produit le payload canonique, le signe avec Ed25519, chiffre le contenu confidentiel et génère le visuel.
5. **Personnalisation :** filigrane, empreinte et sceau sont appliqués au rendu. L'empreinte de l'exemplaire est enregistrée sous forme pseudonyme.

6. **Téléchargement :** l'acheteur récupère le billet depuis son espace authentifié. Le lien de téléchargement est court-vécu et ne contient aucun secret durable.
7. **Contrôle :** l'agent autorisé scanne le QR ou code visuel. Le terminal transmet un jeton de vérification à l'API ; il ne décide pas seul de l'admission.
8. **Décision :** le serveur vérifie la signature, l'événement, le créneau, la porte, le statut, l'affectation et l'absence de consommation. La consommation est atomique.
9. **Audit :** les tentatives répétées, les transferts, les refus et les anomalies sont corrélés dans un journal d'audit à accès restreint.
10. **Enquête :** l'auditeur anti-fraude soumet une image suspecte à l'analyse (section 1.3) ; la correspondance empreinte–affectation n'est levée que sous justification enregistrée.

2.2.1 Cycle de vie du billet

État initial	Événement	État suivant
RESERVED	paiement confirmé	ISSUED
RESERVED	expiration/échec	EXPIRED
ISSUED	transfert validé	TRANSFERRED
ISSUED	remboursement autorisé	REVOKED
ISSUED	scan valide atomique	CONSUMED
TRANSFERRED	nouvel exemplaire émis	ISSUED (nouvel ID)

Un billet `CONSUMED`, `REVOKED`, `EXPIRED` ou `TRANSFERRED` ne peut pas revenir à `ISSUED` par une mise à jour arbitraire. Toute transition est contrôlée par le domaine métier et journalisée.

2.3 Exigences fonctionnelles

Priorités MoSCoW : M (Must, noyau livré en priorité), S (Should), C (Could).

ID	Fonction	Exigence	Prio.
F-01	Gestion événement	L'organisateur crée, modifie, publie et clôture un événement auquel il est affecté, et téléverse le fond de billet (image soumise aux limites de décodage du document d'exigences).	M
F-02	Catalogue	Le visiteur consulte les événements publiés, les disponibilités et les conditions de vente.	M
F-03	Réservation	L'acheteur réserve une quantité de billets dans la limite du quota par compte et par événement.	M
F-04	Paiement	Le serveur confirme le paiement par notification signée du prestataire (simulé en environnement de test) ; les notifications répétées sont idempotentes.	M
F-05	Émission	Un billet est émis après confirmation du paiement et porte un identifiant non prédictible.	M

ID	Fonction	Exigence	Prio.
F-06	Personnalisation	Le rendu comprend un filigrane d'émetteur et une empreinte de copie (robustes) ainsi qu'un sceau stéganographique chiffré/authentifié (fragile).	M
F-07	Portefeuille	L'acheteur consulte, télécharge et présente uniquement ses billets actifs.	M
F-08	Transfert	Le titulaire initie un transfert selon les règles de l'organisateur ; l'ancien billet est invalidé avant l'activation du nouveau.	S
F-09	Scan	L'agent vérifie un billet pour un événement, une porte et une plage horaire autorisés.	M
F-10	Anti-rejeu	Une consommation réussie est atomique ; une seconde présentation est refusée.	M
F-11	Anti-fraude	Le système signale les volumes anormaux, tentatives répétées, achats automatisés et fuites identifiées (règles de vélocité simples).	S
F-12	Audit	L'auditeur consulte les événements de sécurité autorisés ; l'export d'un rapport minimisé est un complément (Could).	M
F-13	Administration	L'administrateur gère les comptes et configurations techniques sans pouvoir altérer discrètement les preuves métier.	M
F-14	Révocation	L'organisateur révoque un billet avec motif, horodatage et auteur identifiés.	S
F-15	Analyse d'image	L'auditeur soumet une image suspecte ; le serveur extrait filigrane, empreinte et sceau, vérifie leur authenticité et indique l'émetteur, l'exemplaire (sous habilitation) et l'état du sceau, ou « non concluant ».	M

2.4 Rôles et habilitations RBAC/ABAC

Le contrôle d'accès combine un rôle (RBAC) et des attributs de contexte (ABAC). Le principe est le refus par défaut : toute action non explicitement autorisée est refusée. Les contrôles sont effectués côté serveur à chaque requête ; masquer un bouton dans la SPA ne constitue pas une mesure de sécurité.

Rôle	Ressources	Autorisations	Restrictions ABAC
Organisateur	Ses événements et ventes	Créer événement, définir quotas, consulter ventes agrégées, révoquer selon procédure	`event.ownerId = subject.id` ; pas d'accès aux secrets globaux ni aux données d'autres organisateurs

Rôle	Ressources	Autorisations	Restrictions ABAC
Acheteur	Son portefeuille	Acheter, télécharger, présenter, demander transfert/remboursement	`ticket.holderId = subject.id` ; accès limité à ses propres billets
Agent de scan	Billets présentés et événement assigné	Vérifier et consommer un billet, consulter le résultat minimal	événement, porte, créneau et terminal doivent correspondre à l'affectation active
Auditeur anti-fraude	Alertes et journaux autorisés	Rechercher des anomalies, soumettre une image suspecte à l'analyse, examiner une fuite, produire un rapport	accès en lecture, justification obligatoire, périmètre d'enquête et durée limitée
Administrateur	Comptes et configuration technique	Gérer comptes, rôles, paramètres et disponibilité	aucun droit implicite de modifier un billet consommé ou d'effacer les traces ; opérations privilégiées séparées

Règles de séparation des pouvoirs

L'administrateur technique ne doit pas pouvoir modifier silencieusement l'historique de vente ou de scan. L'auditeur ne peut pas émettre ou révoquer un billet. L'agent de scan ne peut pas rechercher le portefeuille complet d'un acheteur. Les opérations sensibles exigent une justification et une trace d'audit.

2.5 Architecture technique cible

2.5.1 Vue logique

- **PWA/SPA :** interface responsive, service worker, cache limité aux ressources statiques et données non sensibles.
- **API REST :** endpoints versionnés, HTTPS obligatoire, validation des entrées, pagination et limites de débit.
- **Couche identité :** authentification, sessions, récupération de compte, gestion des rôles et attributs.
- **Services métier :** événements, catalogue, réservation, paiement, émission, transfert, scan et anti-fraude.
- **Services de preuve :** canonicalisation, signature Ed25519, chiffrement authentifié, et moteur de marquage (filigrane, empreinte, sceau) implémenté comme module Java autonome s'appuyant sur `javax.imageio`.
- **Persistance :** base relationnelle transactionnelle, stockage objet privé pour les rendus, journal d'audit séparé.
- **Services externes :** prestataire de paiement, service de notification et éventuellement service de gestion de clés.

2.5.2 Frontières de confiance

Zone	Actifs	Contrôles imposés
Z0 Client	Navigateur, PWA, appareil acheteur	Considéré compromis ; aucune décision d'autorisation locale ; CSP, protection XSS, stockage minimal.
Z1 Réseau public	Internet, terminaux de scan	TLS, limitation de débit, validation des jetons, protection contre rejeu et usurpation.
Z2 API	Contrôleurs REST	Authentification, autorisation objet/fonction, validation, anti-CSRF si cookies, quotas.
Z3 Services métier	Paiement, émission, transfert, scan	Transactions, idempotence, règles métier centralisées, séparation des responsabilités.
Z4 Données	Base, stockage objet, audit	Chiffrement au repos, contrôle d'accès, sauvegardes, rétention et intégrité des journaux.
Z5 Secrets	Clés privées, clés de chiffrement, secrets de prestataire	Stockage dédié, rotation, accès minimal, sauvegarde protégée, aucune clé dans le dépôt ou le client.
Z6 Tiers	Paiement et notification	Authentification mutuelle ou signature de webhook, allowlist si applicable, validation et idempotence.

2.5.3 Flux REST indicatifs

Méthode	Endpoint	Fonction et règle de sécurité
GET	`/api/v1/events`	Catalogue public filtré ; pagination et limitation de débit.
POST	`/api/v1/reservations`	Réservation ; quota, disponibilité transactionnelle, anti-automation.
POST	`/api/v1/payments/webhook`	Confirmation prestataire ; signature vérifiée, idempotence et anti-rejeu.
GET	`/api/v1/me/tickets`	Portefeuille ; identité du titulaire dérivée du principal authentifié.
POST	`/api/v1/tickets/{id}/transfer`	Transfert ; contrôle de propriété, confirmation et invalidation atomique.
POST	`/api/v1/tickets/verify`	Vérification à l'entrée ; agent assigné, événement et porte autorisés.
POST	`/api/v1/tickets/consume`	Consommation atomique ; une seule requête concurrente peut réussir.
POST	`/api/v1/forensics/analyze`	Analyse d'image suspecte ; auditeur habilité, justification enregistrée, taille et dimensions plafonnées.
GET	`/api/v1/audit/cases/{id}`	Consultation d'enquête ; auditeur habilité et justification enregistrée.

2.5.4 Socle Java 25 / Jakarta EE 11 / WildFly 42

— **Jakarta RESTful Web Services 4.0 :** exposition des API REST.

— **Jakarta Security 4.0 :** intégration des mécanismes d'authentification et de l'identité applicative. L'autorisation métier fine reste explicitement appliquée dans les services.

— **Jakarta Persistence 3.2 :** persistance transactionnelle et contraintes d'intégrité.

— **Jakarta Validation 3.1 :** validation déclarative des DTO et paramètres.

— **Jakarta Concurrency 3.1 :** `ManagedExecutorService` à file bornée pour le marquage et l'analyse d'images ; tâche planifiée pour l'expiration des réservations.

— **Record Types :** DTO immuables pour les requêtes/réponses et objets de valeur ; ne pas exposer directement les entités JPA.

— **Virtual Threads :** traitement concurrent des opérations bloquantes d'I/O, après vérification de compatibilité des bibliothèques et du pool JDBC. Ils n'accélèrent pas le calcul CPU intensif.

— **Argon2id :** hachage des mots de passe avec sel unique et paramètres calibrés ; bibliothèque spécialisée maintenue, paramètres réévalués périodiquement.

— **Ed25519 :** signature des claims canoniques des billets via l'API JCA du JDK ; clé privée conservée côté serveur dans un stockage protégé.

— **Durcissement WildFly :** sous-système Elytron pour l'identité et le stockage des secrets ;

interface de management non exposée ; en-têtes de sécurité et limites de requête configurés au niveau du serveur web (Undertow).

Précision de compatibilité

WildFly recommande Java SE 25 pour sa version standard et prend en charge Jakarta EE 11. En revanche, les preuves de compatibilité EE 11 publiées par le projet WildFly portent sur Java SE 17 et 21 : le projet ne revendique pas la compatibilité EE 11 sur Java SE 25. Le choix Java 25 est donc accompagné de tests d'intégration et de non-régression propres à Tessera, et ne doit pas être présenté comme une certification TCK EE 11 sur cette version.

2.6 Exigences non fonctionnelles

ID	Attribut	Cible de validation
NF-01	Performance scan	Sous charge nominale de 100 vérifications/s, 95% des décisions serveur en moins de 500 ms, hors latence réseau du terminal.
NF-02	Disponibilité	Objectif de conception de 99,5% de disponibilité mensuelle pour l'API de contrôle, vérifié ici par des tests de charge et de reprise (et non par une mesure sur 30 jours).
NF-03	Concurrence	Sur 100 scans simultanés du même billet, exactement un seul résultat d'admission peut être positif.
NF-04	Résilience	En cas d'indisponibilité du serveur de validation, le terminal n'accorde pas automatiquement l'accès ; procédure manuelle contrôlée et journalisée.
NF-05	Traçabilité	Toute action privilégiée et toute décision de scan sont journalisées avec horodatage UTC, acteur pseudonyme, événement et résultat.
NF-06	Compatibilité	PWA testée sur les deux dernières versions majeures des navigateurs mobiles ciblés.
NF-07	Accessibilité	Parcours d'achat et portefeuille utilisables au clavier et avec lecteur d'écran ; contraste conforme à WCAG 2.2 AA comme objectif.
NF-08	Traitement d'image	Image acceptée jusqu'à 5 Mo et 16 mégapixels ; marquage d'un rendu ou analyse d'une image suspecte en 10 s au plus ; au-delà des limites, rejet immédiat.

2.7 Exigences réglementaires et vie privée

2.7.1 RGPD et minimisation

Le RGPD est retenu comme cadre de référence pour les traitements de données personnelles lorsque son champ d'application est rempli. Les principes applicables incluent la licéité, la limitation des finalités, la minimisation, l'exactitude, la limitation de conservation, l'intégrité et

la confidentialité. La protection des données dès la conception et par défaut doit être intégrée au développement.

— Ne pas encoder nom, adresse électronique, téléphone ou numéro de document dans le payload visible ou stéganographique.

— Utiliser un identifiant pseudonyme pour l'empreinte acheteur ; conserver la table de correspondance séparément et sous contrôle d'accès renforcé.

— Séparer les données de paiement (gérées par le prestataire) des données de billetterie ; ne jamais stocker les données de carte complètes.

— Définir des durées de conservation par catégorie : compte, transaction, billet, scan, enquête et journaux techniques.

— Permettre l'exercice des droits applicables : accès, rectification, effacement, limitation et opposition, sous réserve des obligations légales de conservation.

— Documenter les finalités, bases légales, destinataires, transferts éventuels et mesures de sécurité ; réaliser une analyse d'impact si le niveau de risque l'exige.

2.7.2 Revente et scalping : règle de prudence juridique

Il n'existe pas une règle universelle interdisant toute revente de billets. Les règles varient selon le pays, le type d'événement, le statut du revendeur et les conditions de vente. Dans l'Union européenne, la revente n'est pas uniformément interdite au niveau de l'UE ; les règles de protection des consommateurs et les législations nationales peuvent néanmoins encadrer les pratiques, notamment l'usage de bots ou les informations communiquées aux acheteurs.

Pour un déploiement en Tunisie, les textes tunisiens applicables, les conditions des organisateurs et les règles propres à chaque événement devront faire l'objet d'une validation juridique locale avant mise en production. Le projet ne doit pas présenter une politique technique anti-scalping comme une règle de droit. Tessera applique donc une politique configurable : plafonds d'achat, transfert officiel, traçabilité, blocage des billets signalés et procédure de contestation.

3 Plan de réalisation et livrables

3.1 Dimensionnement pour un binôme

Le périmètre est limité à ce qu'un binôme peut livrer, tester et défendre. Les exigences de sécurité restent complètes ; seul le périmètre métier est dimensionné à l'effectif.

— **Noyau (Must) :** F-01 à F-07, F-09, F-10, F-12, F-13 et F-15 : événement, réservation, paiement via un prestataire simulé (webhook signé), émission avec filigrane, empreinte et sceau, portefeuille, scan avec consommation atomique, journal d'audit, administration et analyse d'image.

— **Should :** transfert officiel (F-08), anti-fraude à règles de vélocité simples (F-11), révocation (F-14), second facteur TOTP pour les rôles privilégiés.

— **Could :** export du rapport d'audit minimisé, expiration automatique des réservations par règle d'organisateur.

	Exclusion	Conséquence
Exclusions assumées :	Robustesse face à des attaques agressives (rognage important, re-photographie, filtres lourds)	Résultat « non concluant » ; aucune attribut douteuse.
	Résistance à la collusion (comparaison de plusieurs copies)	Non garantie ; risque résiduel documenté.
	Contrôle hors ligne	Non supporté : en cas de panne du serveur, r par défaut et procédure manuelle journalisée
	Paiement réel, fiscalité	Prestataire simulé ; interface isolée pour un branchement ultérieur.
	Place de marché secondaire, application mobile native	Hors périmètre : PWA et transfert officiel uniquement.
	Analyse d'impact RGPD complète	Principes appliqués ; analyse formelle hors périmètre.

3.2 Découpage et planning

Le calendrier couvre quatre semaines de réalisation après la remise des documents.

Phase	Sem.	Livrable	Contenu et validation
P1	S0	Cadrage	Cas d'usage, acteurs, règles de vente, modèle de données, hypothèses de conformité ; cahier des charges et document d'exigences en PDF sous `/docs`.
P2	S1	Socle technique	Projet Jakarta EE, configuration WildFly, API REST, pipeline CI et base de données.
P3	S1	Identité et accès	Authentification, Argon2id, sessions, RBAC/ABAC et tests d'accès.
P4	S2	Billetterie	Catalogue, réservation, paiement simulé, émission et cycle de vie.
P5	S2	Preuves visuelles	Signature Ed25519, chiffrement, moteur de marquage (filigrane, empreinte, sceau) et banc d'attaques sur les marques.
P6	S3	Contrôle	Application de scan, vérification serveur, consommation atomique, analyse d'image ; transfert (Should).
P7	S3–S4	Sécurité	STRIDE, abuse cases, SAST/SCA/DAST, tests de charge et rapport de remédiation.
P8	S4	Livraison	Documentation, démonstration, résultats de tests et limites connues.

3.3 Répartition et méthode de travail

Mohamed Fourat Boujdaria prend l'API Jakarta EE, la persistance, l'identité et le contrôle d'accès, le paiement, le scan et l'anti-rejeu ; Brahim Cheikh prend le moteur de marquage, les services de preuve (signature, chiffrement), la PWA et l'application de scan. Les exigences de sécurité, les tests de sécurité et le déploiement sont partagés ; chaque pull request est relue par l'autre membre.

Les tickets GitHub Issues sont étiquetés `abuse-case`, `security-requirement`, `feature` et `requirement-change` ; chaque exigence de sécurité porte un identifiant `SEC-xxx` référencé dans le code et les tests. Le document d'exigences évolue avec le cours ; chaque changement est daté et justifié.

3.4 Correspondance avec le programme du cours

Chapitre	Application dans Tessera
2. Méthodologies, spécification, conception	STRIDE par composant, cas d'abus, notation OWASP Risk Rating, exigences SMART
3. Confidentialité, intégrité, disponibilité	Signature Ed25519, chiffrement authentifié, TLS, limites de décodage d'images (pixel flood), anti-rejeu
4. Authentification, autorisation, informations privées	Argon2id, sessions, RBAC/ABAC, protection BOLA, minimisation et pseudonymisation
5. Journalisation et gestion des erreurs	Audit append-only, erreurs génériques, alertes anti-fraude
6. Tests de sécurité	SAST/SCA/DAST, tests d'autorisation, fuzzing du décodeur d'images, banc d'attaques sur les marques
7. Déploiement et maintenance	Durcissement WildFly, gestion des secrets, SBOM, sauvegardes

3.5 Risques et plan de repli

Risque	Gravité	Parade
Calendrier trop ambitieux	Élevée	Ordre de coupe ci-dessous
Robustesse insuffisante du filigrane et de l'empreinte	Moyenne à élevée	Évaluation précoce en S2 sur un corpus d'images ; en dernier recours, objectif limité aux transformations modérées avec résultat « non concluant » explicite
Compatibilité WildFly 42 / Java 25 / Jakarta EE 11	Faible à moyenne	Tests d'intégration dès S1
Intégration du paiement	Moyenne	Prestataire simulé avec webhook signé ; interface isolée
Charge mémoire du moteur d'images	Moyenne	Plafonds de décodage et file bornée, tests de charge dès S2

Ordre de coupe en cas de retard : (1) export de rapport, second facteur TOTP et récupération de compte ; (2) transfert officiel (F-08) ; (3) règles anti-fraude réduites à la limitation de débit (F-11) ; (4) objectifs de robustesse du filigrane et de l'empreinte limités aux transformations modérées. **Noyau à ne jamais couper** : signature canonique, consommation atomique, RBAC/ABAC, journal d'audit, émission avec empreinte et sceau, analyse d'image.

3.6 Definition of Done

Une fonctionnalité est considérée terminée lorsque :

— les critères fonctionnels sont testés ;

— les exigences de sécurité applicables sont reliées à des tests ;

— les contrôles d'autorisation sont validés côté serveur ;

— les erreurs ne divulguent ni secrets ni données sensibles ;

— les événements de sécurité attendus sont journalisés ;

— la documentation et les limites connues sont mises à jour ;

— aucune vulnérabilité critique non traitée n'est acceptée sans décision formelle et mesure compensatoire.